Udyam Saathi: Data Privacy & Security Note

Team DevSquad_VITVellore (Abhishek Anand, Utsav Chauhan · VIT Vellore) · YTL Hackathon 2026, Track A · Designed to the Digital Personal Data Protection Act, 2023 (DPDP). All data used is synthetic.

1. What we collect, and why (purpose limitation + data minimisation)

Step	Data	Purpose	Not collected
Advisor	Business type, staff count, sites, city, needs, optional current spend	Recommend an eligible bundle	No name, phone or ID needed to get a price
GSTIN lookup	GSTIN (optional)	Pre-fill business, check eligibility	No turnover or returns data
KYC	GST cert, Udyam cert, signatory ID, address proof (≤90 days)	Legal KYC for business connections; install address	No Aadhaar number stored; no photos of people other than signatory ID
Order	Business name, products, install slot, consent ID	Fulfilment and billing	No payment card data (handled by PCI gateway)

2. Consent (s.6 DPDP)

- A consent screen in the owner's chosen language appears **before** any document upload. It lists each purpose separately: KYC and installation are required; WhatsApp marketing is optional and **off by default**.
- Each consent is written to a **purpose-tagged consent ledger** (consent ID, purposes, language, timestamp, retention text) and linked to the order.
- **Withdrawal is one tap** from the tracker. It triggers deletion of document images and stops optional processing; only records the law requires are kept.

3. Minimising exposure

- **Masking everywhere:** GSTIN, Udyam and ID numbers show only the first 2 and last 3 characters (e.g. 37••••••••••1ZU) in the UI, API responses and logs.
- **In-memory processing:** uploaded images are OCR'd in memory and not written to disk in the prototype. In production they go to an encrypted, access-logged object store.
- **Audit log** records every registry lookup, consent and KYC verdict with masked identifiers only. The back office never sees full IDs.
- **Role-based access:** Saathis (field and partner) see leads, scores and drop reasons, never documents. Only the KYC reviewer role can open a flagged document.
- The propensity model uses business attributes only (segment, size, source, spend). No personal attributes, so there's no profiling of individuals.

4. Retention

Data	Retention
KYC document images	Deleted 30 days after activation (or immediately on rejection, abandonment >30 days, or consent withdrawal)
Extracted KYC fields + verdict	Contract term + period required by DoT/telecom KYC and tax rules; then deleted
Advisor sessions with no order	90 days, then anonymised (segment/city only) for analytics
Audit log	1 year, masked

5. Security controls

- TLS 1.2+ in transit and AES-256 at rest. Secrets are kept in a vault and never in code. Registry, DigiLocker and e-Sign calls go only over signed server-to-server APIs.
- **KYC integrity:** GSTIN mod-36 check digit, registry status (cancelled/suspended blocked), cross-document name/state/date checks, blur and skew detection. Uncertain cases go to a human (NEEDS REVIEW) instead of being auto-approved.
- **GenAI safety:** the language model never sees documents or identifiers and cannot choose products. A deterministic rules engine decides eligibility.
- Rate limits on lookup APIs prevent GSTIN enumeration. File-type and size checks run on uploads.

6. Data principal rights & grievance

- Access, correction and erasure from the tracker or helpline 121. A named Grievance Officer responds within the statutory timeline. Breaches are notified to the Data Protection Board and affected owners as DPDP requires.